

Deploying Privileged Access Workstations in the real world

Mikael Nyström

Principal Technical Architect, Truesec

Microsoft MVP since 2003

deploymentbunny@outlook.com

@mikael_nystrom

Carrots ready. Admin rights optional.



NIC26

Why?



NIC26

How attacks happen

- Stolen logins or software flaws let attackers in
- Stolen credentials can unlock more systems and privileges
- Admin devices hold the VIP keys
- EDR helps. Credential risk remains
- PAWs keep admin work separate from everyday work



NIC26

What PAW protects

- Admin credentials: keys to the kingdom
- Admin tokens: the VIP passes
- Privileged sessions: backstage access
- Access to Tier 0 and Tier 1 systems
- Admin interfaces: on-prem or in the cloud
- And the device holding all those keys



LIVE DEMO 01

DEMO

Prep for PAW in **Active Directory**

What could possibly go wrong?



NIC26

LIVE DEMO 02

DEMO

Prep for PAW in **Entra ID**

Please hold while the cloud thinks.



NIC26

PAW designs

Classic, modern, and hybrid designs



NIC26

Classic vs. modern PAW

Both use a dedicated hardened workstation

Classic

Domain-joined
Tiered admin model
No internet or email
Strong security, less flexibility
Original Microsoft PAW guidance

Modern

Entra ID joined
Strong device compliance
MFA + Conditional Access
Easier to use
More dependencies

Both may need several devices to keep environments separate.



Hybrid PAW in practice

- The device runs a “portable” hypervisor
- Not domain-joined
- Often kept minimal or managed separately
- Locked down to run VMs and nothing else
- A practical choice for many environments



Hybrid PAW in practice

- Separate VMs for each tier
- Separate VMs for each admin interface
- A separate VM for each cloud platform
- Credentials stay separate in each admin environment



NIC26

LIVE DEMO 03

DEMO

Let’s build some PAWs

The PAW Toolkit

Some assembly required. Coffee recommended.



NIC26

```
PS C:\PAWDeploy2> .\PAWDeploy.ps1
```

Identity & Zero Trust

How PAW fits into access control



NIC26

PAW in a Zero Trust model

- Never trust the network
- Always check the device and the identity
- Assume attackers will target credentials
- Keep admin work separate
- Keep checking for risk
- PAW helps enforce Zero Trust rules



NIC26

Admin identities and authentication

- Use separate admin identities
- Conditional Access: allow access only from PAWs
- MFA and phishing-resistant authentication



NIC26

Admin privileges and PIM

- Access based on roles
- JIT/JEA: only the access needed, when needed
- Privileged Identity Management
- PIM limits permanent admin rights and adds checks.
  It cannot replace PAW or stop credential theft.



NIC26

Lessons from the field

What breaks, why, and how to fix it



NIC26

Common PAW problems

- Define the access rules first. PAW helps enforce them.
- Admins work around PAW when it gets in the way
- PAW restrictions stop admins doing their job
- Internet and email exceptions creep in
- No plan to maintain and replace PAWs
- We have seen these problems in practice



Reality check

Security fails when people cannot get their work done



NIC26

Common PAW problems

- Treating PAW as a one-off project
- Trying too hard
- Trying to do too much
- Trying to handle every rare exception
- Indirect admin control also counts as Tier 0
- We have seen these problems in practice



Remember this…

PAW needs ongoing support and clear ways of working



NIC26

What works in practice

- Start with Tier 0, backup, Entra ID and virtualization
- Support from senior management
- Clear steps for admin tasks
- A clearly defined PAW user profile
- A plan to manage change
- Keep improving the setup
- People and working practices matter as much as technology



NIC26

Running PAW across the organization

From pilot to production



NIC26

Day-to-day PAW management

- Roll out in stages using deployment rings
- Clear steps when admins join or leave
- A plan for updates and patches
- A standard set of admin tools
- A plan for security incidents involving PAWs
- PAW needs ongoing support



NIC26

Security that works for admins

- Fast startup and sign-in
- Keep the number of tools down
- Written steps for common tasks
- Carefully controlled exceptions
- Regular feedback from admins
- Admins will work around PAW if it is hard to use



NIC26

Final thoughts

What actually matters



NIC26

If you do only five things

- Use separate admin identities
- Use policies to allow admin access only from PAWs
- Lock down the PAW operating system
- Remove internet and email from PAW
- Keep managing and improving PAW



NIC26

Who needs a PAW?

Role	Typical access	Impact	Internet / email	PAW?
Tier 0 Admin	DCs, Entra ID, sync	Full domain takeover	No	Required
Infrastructure Admin	Servers, hypervisors	Lateral movement	Rare	Strongly recommended
Security Operations	EDR, identity, IR	Control bypass	Limited	Recommended
Cloud / M365 Admin	Tenant-wide settings	Tenant takeover	Sometimes	Recommended
Helpdesk	Endpoints, users	User compromise	Yes	Optional
Standard users	Business apps	Low	Yes	No

NIC26

Thank you

Questions?



NIC26